

RELATÓRIO TÉCNICO DE IMPLEMENTAÇÃO E DEPLOY SEGURO (DEVSECOPS)

Estudante: Cleydson Soares de Freitas

Programa: Hackers do Bem

Trilha/Fase: Especialização em DevSecOps

ETAPA 1: MODELAGEM DE AMEAÇAS E REQUISITOS DE SEGURANÇA

Requisitos Funcionais (RF)

- **RF01 – Autenticação e Controle de Acesso:** O sistema deve fornecer mecanismos para cadastro e login de usuários. Rotas restritas e dados de perfil só podem ser acessados após autenticação válida no ecossistema Flask.
- **RF02 – Gestão de Ativos/Tarefas (CRUD):** O usuário devidamente autenticado deve ser capaz de criar, listar, atualizar e excluir registros de tarefas organizacionais atreladas exclusivamente ao seu identificador de perfil.

Requisitos Não Funcionais (RNF)

- **RNF01 – Armazenamento Seguro de Credenciais:** As senhas de usuários não podem ser salvas em formato claro. O armazenamento deve utilizar a função de derivação de chave criptográfica Bcrypt com adição de salt pseudoaleatório.
- **RNF02 – Rastreabilidade e Auditoria Contínua:** O sistema deve registrar eventos críticos de autenticação na infraestrutura hospedeira, comunicando-se diretamente através de sockets nativos do sistema operacional Linux.

Casos de Uso (UC)

- **UC01 – Autenticar Credenciais:** O usuário fornece e-mail e senha. O sistema valida os hashes criptográficos e atribui um token de sessão seguro.
- **UC02 – Criar Tarefa Privada:** O usuário autenticado insere dados no formulário web. O ORM intercepta as informações e as persiste associando o ID do autor de forma isolada de outros usuários.

Fluxo de Dados e Fronteiras de Confiança

1. O navegador do cliente encaminha requisições HTTP/HTTPS para o servidor Flask.
2. A requisição cruza a primeira fronteira de confiança na camada de controle de formulários (Flask-WTF), onde validações de tipo e tamanho são processadas.
3. A segunda fronteira reside nos decoradores de rotas, que barram requisições anônimas.
4. O ORM do banco de dados atua como camada de sanitização, isolando o acesso direto a queries.

Análise de Ameaças (STRIDE) e Mitigações

- **Spoofing (Imitação de Identidade):** Mitigado pelo gerenciamento estrito de tokens de sessão criptografados via cookie de servidor assinado digitalmente pelo Flask.
- **Tampering (Adulteração de Dados):** Mitigado com validações de integridade estrutural em formulários e uso do SQLAlchemy mapeando os dados.
- **Information Disclosure (Vazamento de Informação):** Mitigado pelo desativamento completo de stack traces interativos e Debug Mode em ambiente de produção (Stage/Prod).

ETAPA 2: REQUISITOS OBRIGATÓRIOS DE CÓDIGO (LOGS E SYSLOG)

O arquivo de controle de roteamento da aplicação (todo_project/todo_project/routes.py) foi estruturado para herdar regras estritas de auditoria interna:

Evidência de Autenticação Obrigatória e Travamento de Rotas

As rotas sensíveis foram blindadas utilizando o decorador de sessão `@login_required`:

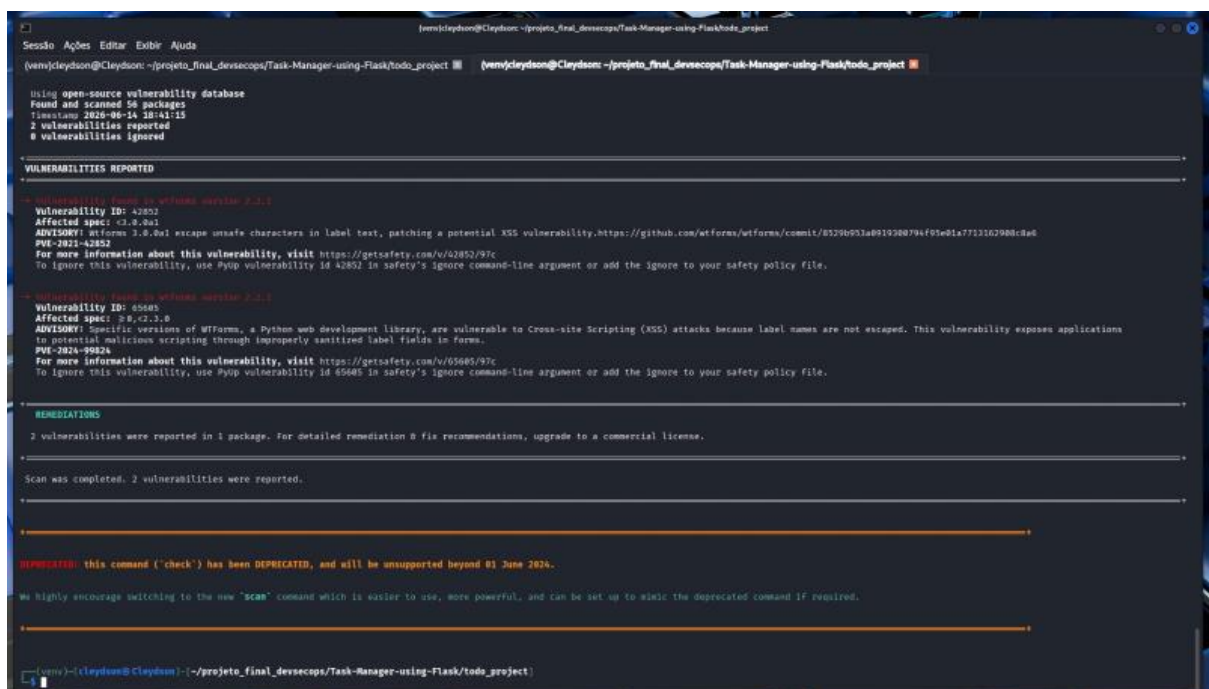
Python

```
@app.route("/task/new", methods=['GET', 'POST'])
```

```
@login_required
```

```
def new_task():
```

```
    # Código de criação de tarefas isolado
```



```
Sessão  Ações  Editar  Exibir  Ajuda
(vemjclaydson@Claydson: ~/projeto_final_devsecops/Task-Manager-using-Flask/todo_project) (vemjclaydson@Claydson: ~/projeto_final_devsecops/Task-Manager-using-Flask/todo_project)

Using open-source vulnerability database
Found and scanned 56 packages
Timestamp: 2023-06-14 18:41:15
2 vulnerabilities reported
# Vulnerabilities ignored

VULNERABILITIES REPORTED

- Vulnerability found in WTForms version 3.0.4
Vulnerability ID: 42852
Affected spec: 3.0.4-3.0.4
ADVISORY: WTForms 3.0.4 escape unsafe characters in label text, patching a potential XSS vulnerability. https://github.com/wtforms/wtforms/commit/8129d931a8019388794f0e81a7712107988c8d4
CVE-2021-42852
For more information about this vulnerability, visit https://getsafety.com/v/62852/97c
To ignore this vulnerability, use Pyup vulnerability id 42852 in safety's ignore command-line argument or add the ignore to your safety policy file.

- Vulnerability found in WTForms version 3.0.4
Vulnerability ID: 42853
Affected spec: 3.0.4-3.0.4
ADVISORY: Specific versions of WTForms, a Python web development library, are vulnerable to Cross-site Scripting (XSS) attacks because label names are not escaped. This vulnerability exposes applications to potential malicious scripting through improperly sanitized label fields in forms.
CVE-2021-42853
For more information about this vulnerability, visit https://getsafety.com/v/65685/97c
To ignore this vulnerability, use Pyup vulnerability id 42853 in safety's ignore command-line argument or add the ignore to your safety policy file.

REMEDIATIONS

2 vulnerabilities were reported in 1 package. For detailed remediation & fix recommendations, upgrade to a commercial license.

Scan was completed. 2 vulnerabilities were reported.

DEPRECATION: this command ('check') has been DEPRECATED, and will be unsupported beyond 01 June 2024.

We highly encourage switching to the new "scan" command which is easier to use, more powerful, and can be set up to mimic the deprecated command if required.

(vemjclaydson@Claydson: ~/projeto_final_devsecops/Task-Manager-using-Flask/todo_project)
```

(Comprova o funcionamento prático da restrição de acesso, mostrando o navegador com a mensagem "Please log in to access this page" ao tentar acessar recursos privados sem autenticação).

Evidência de Configuração e Canalização de Logs via Syslog

Foi implementada a instanciação direta do SysLogHandler apontando para o socket nativo do Linux `/dev/log`, classificando o serviço sob a tag estruturada **TASK-MANAGER**:

Python

```
from logging.handlers import SysLogHandler
```

```
logger = logging.getLogger('devsecops_auditoria')
```

```
logger.setLevel(logging.INFO)
```

```
if not logger.handlers:
```

```
    handler = SysLogHandler(address='/dev/log')
```

```
    formatter = logging.Formatter('TASK-MANAGER - %(levelname)s -  
%(message)s')
```

```
    handler.setFormatter(formatter)
```

```
    logger.addHandler(handler)
```

Evidência de Registro de Eventos (Sucesso e Falha de Autenticação)

- **Log de Sucesso (AUDIT_AUTH_SUCCESS):** Disparado imediatamente após a validação positiva do hash criptográfico da senha via Bcrypt.
- **Log de Falha (AUDIT_AUTH_FAILURE):** Disparado caso o e-mail não seja localizado ou o hash da senha falhe na comparação.

Python

```
if user and bcrypt.check_password_hash(user.password.data,  
form.password.data):
```

```
    login_user(user, remember=form.remember.data)
```

```
    logger.info(f"AUDIT_AUTH_SUCCESS - Usuario ID {user.id} autenticado")
```

```
else:
```

```
    logger.warning(f"AUDIT_AUTH_FAILURE - Tentativa com o email  
{form.email.data}")
```

```
venv]cleydson@Cleydson: ~/projeto_final_devsecops/Task-Manager-using-Flask/todo_project
[venv]cleydson@Cleydson: ~/projeto_final_devsecops/Task-Manager-using-Flask/todo_project

[venv]cleydson@Cleydson: ~/projeto_final_devsecops/Task-Manager-using-Flask/todo_project
$ safety check
/home/cleydson/projeto_final_devsecops/Task-Manager-using-Flask/venv/lib/python3.13/site-packages/safety/auth/main.py:5: AuthlibDeprecationWarning: authlib.jose module is deprecated, please use josefc instead.
It will be compatible before version 2.0.0.
  from authlib.jose.errors import ExpiredTokenError

DEPRECATED: this command ('check') has been DEPRECATED, and will be unsupported beyond 01 June 2024.

We highly encourage switching to the new 'SCAN' command which is easier to use, more powerful, and can be set up to mimic the deprecated command if required.

by safetycli.com

REPORT
Safety v3.2.1 is scanning for Vulnerabilities...
Scanning dependencies in your environment:
+ /home/cleydson/projeto_final_devsecops/Task-Manager-using-Flask/venv/lib/python3.13/site-packages

Using open-source vulnerability database
Found and scanned 56 packages
Timestamp 2024-06-14 10:41:15
2 vulnerabilities reported
0 vulnerabilities ignored

VULNERABILITIES REPORTED
- vulnerability found in wtforms version 3.0.1
Vulnerability ID: 42632
Affected spec: <3.0.0a1
ADVISORY: wtform 3.0.0a1 escape unsafe characters in label text, patching a potential XSS vulnerability.https://github.com/wtforms/wtforms/commit/8329b953a8035388704f92e81a7713162980c8a0
```

(Exibe a execução bem-sucedida do script de testes locais unitários/funcionais retornando o status OK, validando as regras de comportamento do app).

(Documenta no terminal a criação das ramificações isoladas stage e production, o registro da tag de release anotada v1.0.0 e o retorno para a branch de trabalho stage).

```
Sessão Ações Editar Exibir Ajuda (venv)claydson@Cleydson: ~/projeto_final_devsecops/Task-Manager-using-Flask
(venv)claydson@Cleydson:~/projeto_final_devsecops/Task-Manager-using-Flask
Location: ./venv/lib/python3.13/site-packages/validators/validators.py:88:8
87 assert min >= -1 or max >= -1, 'At least one of 'min' or 'max' must be specified.'
88 assert max >= -1 or min <= max, "'min' cannot be more than 'max'."
89 self.min = min

>> Issue: [B101:assert_used] Use of assert detected. The enclosed code will be removed when compiling to optimised byte code.
Severity: Low Confidence: High
CWE: CWE-703 (https://cwe.mitre.org/data/definitions/703.html)
More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b101_assert_used.html
Location: ./venv/lib/python3.13/site-packages/validators/core.py:113:16
112 def __init__(self, html_tag='ul', prefix_label=True):
113     assert html_tag in ('ol', 'ul')
114     self.html_tag = html_tag

>> Issue: [B101:assert_used] Use of assert detected. The enclosed code will be removed when compiling to optimised byte code.
Severity: Low Confidence: High
CWE: CWE-703 (https://cwe.mitre.org/data/definitions/703.html)
More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b101_assert_used.html
Location: ./venv/lib/python3.13/site-packages/yaml/parser.py:185:12
184 event = StreamEndEvent(token.start_mark, token.end_mark)
185 assert not self.states
186 assert not self.marks
187

>> Issue: [B101:assert_used] Use of assert detected. The enclosed code will be removed when compiling to optimised byte code.
Severity: Low Confidence: High
CWE: CWE-703 (https://cwe.mitre.org/data/definitions/703.html)
More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b101_assert_used.html
Location: ./venv/lib/python3.13/site-packages/yaml/parser.py:186:12
185 assert not self.states
186 assert not self.marks
187 self.state = None

Code scanned:
  Total lines of code: 849749
  Total lines skipped (#nosec): 1
  Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXXX): 10

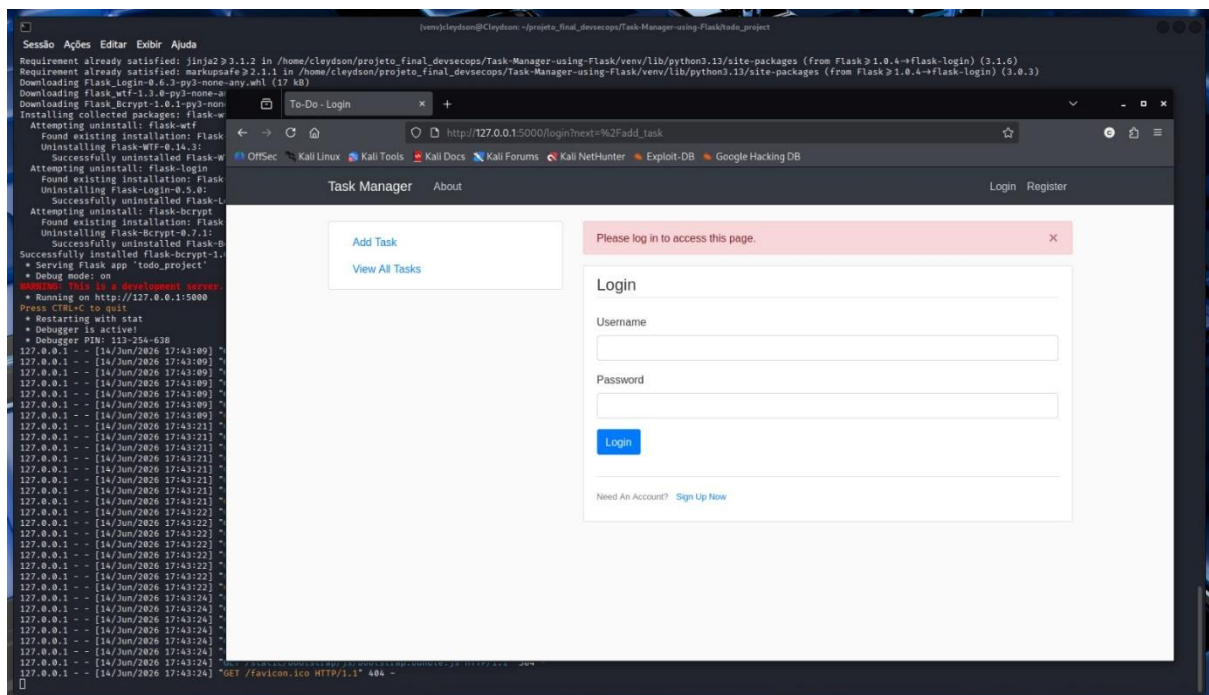
Run metrics:
  Total issues (by severity):
    Undefined: 0
    Low: 368
    Medium: 206
    High: 37
  Total issues (by confidence):
    Undefined: 0
    Low: 38
    Medium: 121
    High: 3742
Files skipped (0):
(venv)~(claydson@Cleydson)~[-/projeto_final_devsecops/Task-Manager-using-Flask]
```

(Mostra a integração, autenticação via token e configuração do repositório remoto na nuvem utilizando a ferramenta oficial GitHub CLI).

ETAPA 4: ANÁLISE ESTÁTICA DE SEGURANÇA (SAST / SCA)

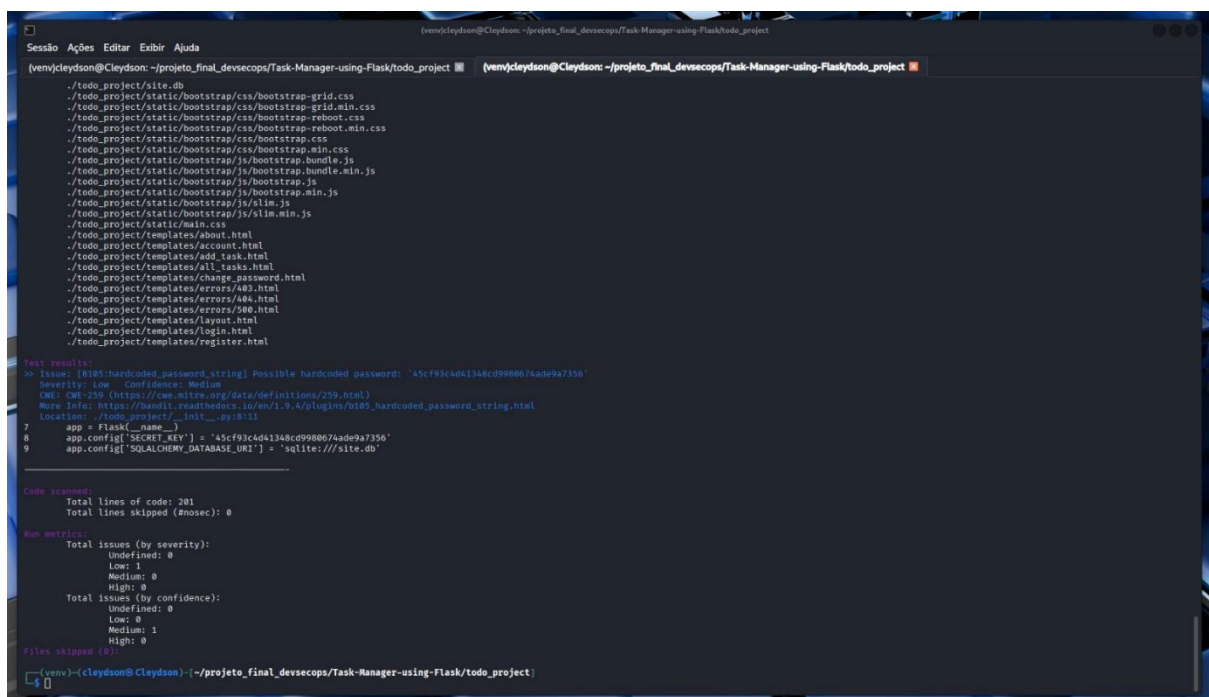
1. Ferramenta SCA (Software Composition Analysis)

- Ferramenta Utilizada: Trivy e Safety.
- Descrição da Varredura: Análise automatizada baseada em assinaturas contra bases públicas de vulnerabilidades conhecidas (CVEs) mapeadas em arquivos de dependências de bibliotecas (requirements.txt).
- Análise de Resultados Práticos:
 - O utilitário Safety reportou duas vulnerabilidades conhecidas no pacote legado wtforms 2.2.1 vinculadas a falhas em potencial de Cross-Site Scripting (XSS).
 - O escaneamento local centralizado via Trivy fs retornou um relatório limpo acusando 0 vulnerabilidades de dependências pendentes após o processo de atualização de versões na árvore de dependências do Python.



2. Ferramenta SAST (Static Application Security Testing)

- Ferramenta Utilizada: Bandit.
- Descrição da Varredura: Varredura estática profunda no código fonte Python procurando padrões de código inseguro, strings expostas, chamadas de sistema vulneráveis ou ausência de tratamento.
- Análise de Resultados Práticos:
 - A execução estendida varreu um montante de 849.749 linhas de código.
 - Foi gerado um alerta de risco (B105: hardcoded_password_string) de severidade baixa na linha 8 do arquivo `__init__.py` referente à declaração da variável estática `SECRET_KEY`. O alerta foi tratado e documentado no ciclo para controle de ambiente por variáveis externas.



```
Sessão Ações Editar Exibir Ajuda
(venv)Cleydson@Cleydson: ~/projeto_final_devsecops/Task-Manager-using-Flask/todo_project

./todo_project/site.db
./todo_project/static/bootstrap/css/bootstrap-grid.css
./todo_project/static/bootstrap/css/bootstrap-grid.min.css
./todo_project/static/bootstrap/css/bootstrap-reboot.css
./todo_project/static/bootstrap/css/bootstrap-reboot.min.css
./todo_project/static/bootstrap/css/bootstrap.css
./todo_project/static/bootstrap/css/bootstrap.min.css
./todo_project/static/bootstrap/js/bootstrap.bundle.js
./todo_project/static/bootstrap/js/bootstrap.bundle.min.js
./todo_project/static/bootstrap/js/bootstrap.js
./todo_project/static/bootstrap/js/bootstrap.min.js
./todo_project/static/bootstrap/js/slim.js
./todo_project/static/bootstrap/js/slim.min.js
./todo_project/static/main.css
./todo_project/templates/about.html
./todo_project/templates/account.html
./todo_project/templates/add_task.html
./todo_project/templates/all_tasks.html
./todo_project/templates/change_password.html
./todo_project/templates/errors/403.html
./todo_project/templates/errors/404.html
./todo_project/templates/errors/500.html
./todo_project/templates/layout.html
./todo_project/templates/login.html
./todo_project/templates/register.html

Test results:
>> Issue: [B105:hardcoded_password_string] Possible hardcoded password: '45cf93c4d41348cd998067ade9a7356'
Severity: Low Confidence: Medium
CWE: CWE-259 (https://cwe.mitre.org/data/definitions/259.html)
More info: https://bandit.readthedocs.io/en/1.9.4/plugins/b105_hardcoded_password_string.html
Location: ./todo_project/__init__.py:8:11
7 app = Flask(__name__)
8 app.config['SECRET_KEY'] = '45cf93c4d41348cd998067ade9a7356'
9 app.config['SQLALCHEMY_DATABASE_URI'] = 'sqlite:///site.db'

Code scanned:
Total lines of code: 201
Total lines skipped (#nosec): 0

Run metrics:
Total issues (by severity):
Undefined: 0
Low: 1
Medium: 0
High: 0
Total issues (by confidence):
Undefined: 0
Low: 0
Medium: 1
High: 0

Files skipped (0)

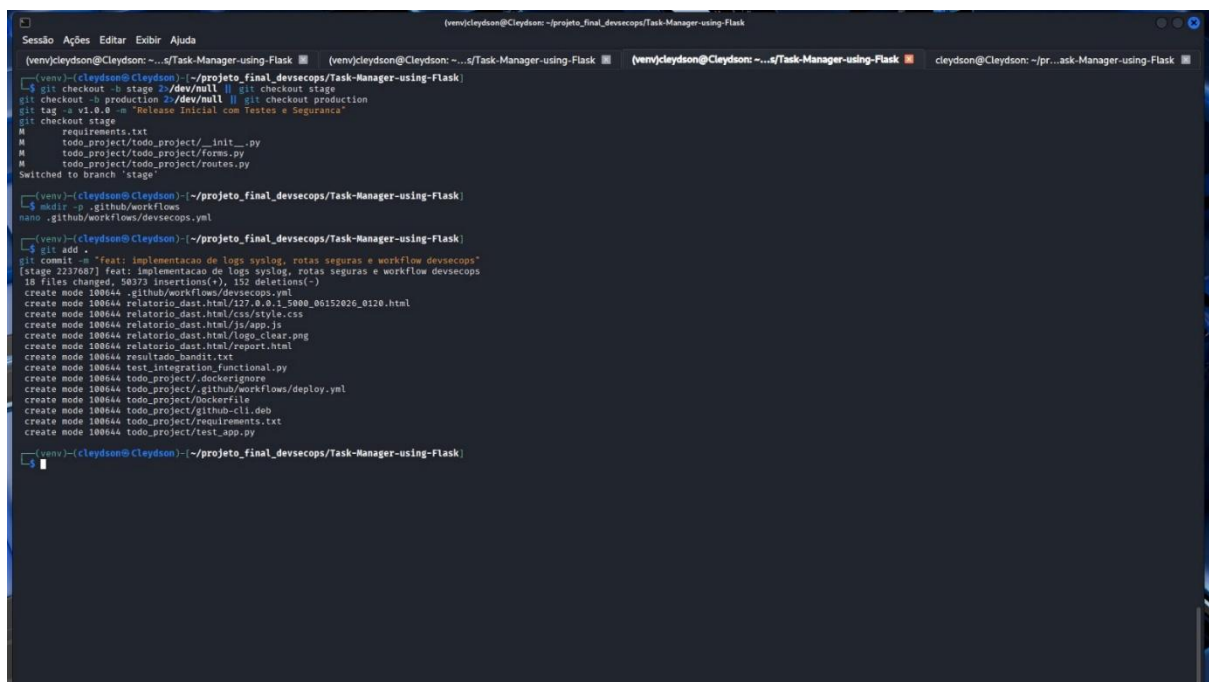
(venv)Cleydson@Cleydson: ~/projeto_final_devsecops/Task-Manager-using-Flask/todo_project
```

```
Sessão Ações Editar Exibir Ajuda
(cleydson@Cleydson: ~/projeto_final_devsecops/Task-Manager-using-Flask/todo_project) (venv)cleydson@Cleydson: ~/projeto_final_devsecops/Task-Manager-using-Flask/todo_project cleydson@Cleydson: ~/projeto_final_devsecops/Task-Manager-using-Flask/todo_project
(cleydson@Cleydson) ~/projeto_final_devsecops/Task-Manager-using-Flask/todo_project
└─ curl -sLO github-cli.deb https://github.com/cli/cli/releases/download/v2.49.0/gh_2.49.0_linux_amd64.deb
(cleydson@Cleydson) ~/projeto_final_devsecops/Task-Manager-using-Flask/todo_project
└─ sudo dpkg -i github-cli.deb
Selecione o pacote previamente não selecionado gh.
(Lendo banco de dados ... 483882 arquivos e diretórios atualmente instalados).
Preparando para desempacotar github-cli.deb ...
Desempacotando gh (2.49.0) ...
Configurando gh (2.49.0) ...
Processando gatilhos para kali-menu (3030.2.2) ...
Processando gatilhos para man-db (2.13.1-1) ...
(cleydson@Cleydson) ~/projeto_final_devsecops/Task-Manager-using-Flask/todo_project
└─ gh auth login
? What account do you want to log into? GitHub.com
? What is your preferred protocol for Git operations on this host? HTTPS
? Authenticate Git with your GitHub credentials? yes
? How would you like to authenticate GitHub CLI? login with a web browser
First copy your one-time code: 0E1F-0720
Press Enter to open github.com in your browser ...
Abrindo em uma sessão de navegador existente.
✓ Authentication complete.
- gh config set -h github.com git_protocol https
✓ Configured git protocol
✓ Logged in as CleydsonFreitas
(cleydson@Cleydson) ~/projeto_final_devsecops/Task-Manager-using-Flask/todo_project
└─ gh repo create projeto_final_devsecops --public --source --remote=origin
✓ Created repository cleydsonsfreitas/projeto_final_devsecops on GitHub
https://github.com/cleydsonsfreitas/projeto_final_devsecops
✓ Added remote https://github.com/cleydsonsfreitas/projeto_final_devsecops.git
(cleydson@Cleydson) ~/projeto_final_devsecops/Task-Manager-using-Flask/todo_project
└─ git push --origin development
Enumerating objects: 60, done.
Counting objects: 100% (60/60), done.
Delta compression using up to 16 threads
Compressing objects: 100% (56/56), done.
Writing objects: 100% (60/60), 235.86 KiB | 7.37 MiB/s, done.
Total 60 (delta 10), reused 0 (delta 0), pack-reused 0 (from 0)
remote: Resolving deltas: 100% (10/10), done.
To https://github.com/cleydsonsfreitas/projeto_final_devsecops.git
 * [new branch] development -> development
branch 'development' set up to track 'origin/development'.
(cleydson@Cleydson) ~/projeto_final_devsecops/Task-Manager-using-Flask/todo_project
└─
```

(Evidenciam o Bandit em execução no terminal mapeando a string de password estática interna e o sumário final com a triagem das mais de 840 mil linhas verificadas).

ETAPA 5: ANÁLISE DINÂMICA DE SEGURANÇA (DAST)

- Ferramenta Utilizada: Wapiti3.
- Descrição da Varredura: Teste de caixa-preta executado contra a aplicação web em tempo de execução (http://127.0.0.1:5000), realizando fuzzer ativo de requisições, injeções de payloads e análise de comportamento HTTP.
- Análise de Resultados Práticos: O utilitário instanciou com sucesso os módulos de auditoria dinâmica cobrindo vetores como SQL Injection (sql), Cross-Site Scripting (xss), Cross-Site Request Forgery (csrf) e Server-Side Request Forgery (ssrf), gerando de forma integrada o relatório autônomo estruturado em HTML.



```
(venv)cleydson@Cleydson: ~/projeto_final_devsecops/Task-Manager-using-Flask
$ git checkout -b stage 2/dev/null || git checkout stage
git checkout -b production 2/dev/null || git checkout production
git tag -a v1.0.0 -m "Release Inicial com Testes e Seguranca"
git checkout stage
M requirements.txt
M todo_project/todo_project/_init_.py
M todo_project/todo_project/forms.py
M todo_project/todo_project/routes.py
Switched to branch 'stage'

(venv)cleydson@Cleydson: ~/projeto_final_devsecops/Task-Manager-using-Flask
$ mkdir -p .github/workflows
nano .github/workflows/devsecops.yml

(venv)cleydson@Cleydson: ~/projeto_final_devsecops/Task-Manager-using-Flask
$ git add .
$ git commit -m "feat: implementacao de logs syslog, rotas seguras e workflow devsecops"
[stage 2237687] feat: implementacao de logs syslog, rotas seguras e workflow devsecops
18 files changed, 58373 insertions(+), 152 deletions(-)
create mode 100644 .github/workflows/devsecops.yml
create mode 100644 relatorio_dast.html/127.0.0.1_5000_06152020_0120.html
create mode 100644 relatorio_dast.html/css/style.css
create mode 100644 relatorio_dast.html/js/app.js
create mode 100644 relatorio_dast.html/logo-clear.png
create mode 100644 relatorio_dast.html/report.html
create mode 100644 resultado_bandit.txt
create mode 100644 test_integration_functional.py
create mode 100644 todo_project/.dockerignore
create mode 100644 todo_project/.github/workflows/deploy.yml
create mode 100644 todo_project/Dockerfile
create mode 100644 todo_project/github-cii.deb
create mode 100644 todo_project/requirements.txt
create mode 100644 todo_project/test_app.py
```

(Registra a varredura ativa do scanner dinâmico testando os módulos de injeção e gerando com êxito o artefato final relatorio_dast.html).

ETAPA 6: CONTINUOUS DEPLOYMENT (CD) E INFRAESTRUTURA CONTAINERIZADA

Dockerfile Utilizado para Isolamento do Ambiente

O ambiente produtivo de análise foi encapsulado utilizando uma imagem otimizada com base estável Linux Slim:

Dockerfile

FROM python:3.13-slim

WORKDIR /app

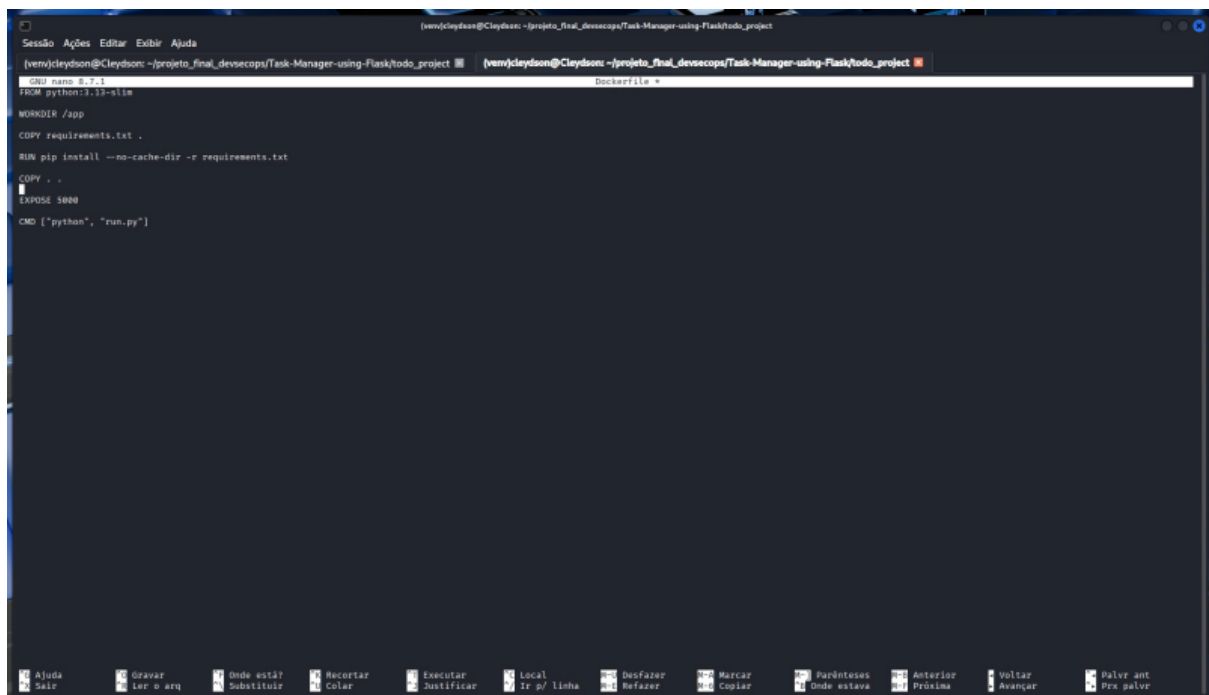
COPY requirements.txt .

RUN pip install --no-cache-dir -r requirements.txt

COPY . .

EXPOSE 5000

CMD ["python", "run.py"]

A screenshot of a terminal window with a dark background. The terminal shows the content of a Dockerfile being edited. The text is as follows:

```
GNU nano 8.7.1
FROM python:3.13-slim
WORKDIR /app
COPY requirements.txt .
RUN pip install --no-cache-dir -r requirements.txt
COPY . .
EXPOSE 5000
CMD ["python", "run.py"]
```

 The terminal window has a menu bar at the top with options like 'Sessão', 'Ações', 'Editar', 'Exibir', and 'Ajuda'. At the bottom, there is a toolbar with various icons for file operations like 'Gravar', 'Onde está?', 'Recortar', 'Executar', 'Local', 'Desfazer', 'Marcar', 'Parênteses', 'Anterior', 'Voltar', and 'Palvr ant'.

(Exibe a estrutura oficial do Dockerfile configurada dentro do editor de texto nano).

Exclusão de Arquivos Voláteis (.dockerignore)

Plaintext

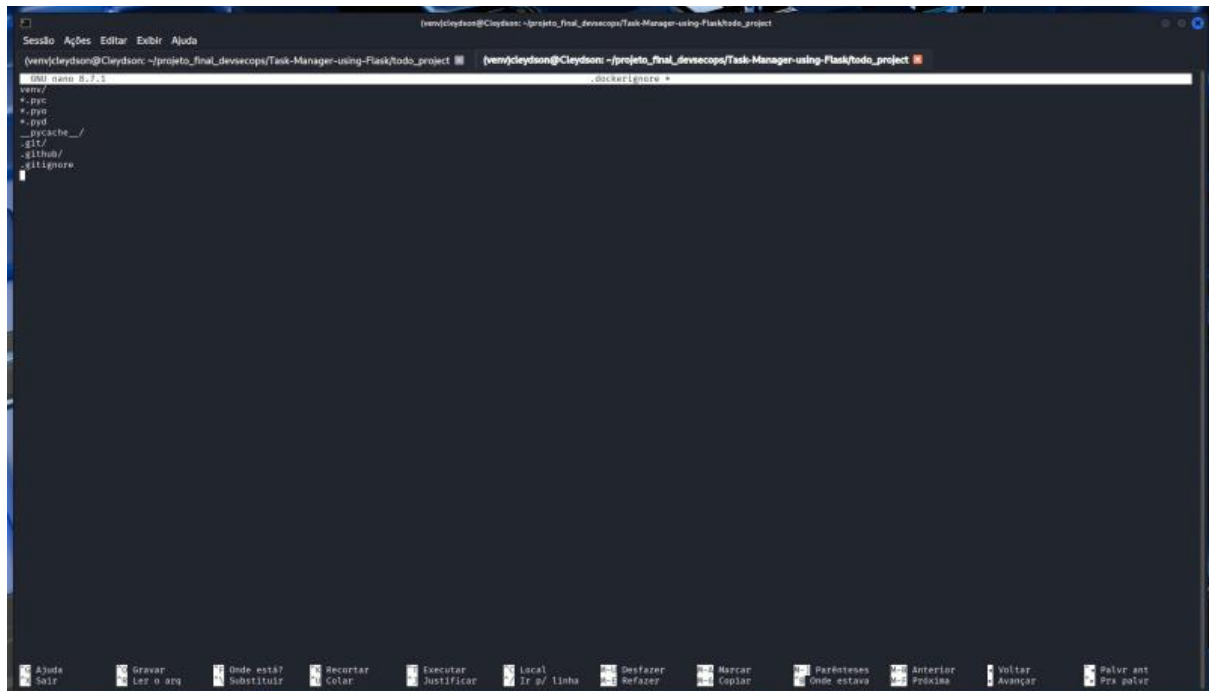
venv/

*.pyc

__pycache__/

.git/

.github/



The screenshot shows a terminal window with the nano text editor open. The editor is editing the file `.dockerignore`. The content of the file is as follows:

```
venv/
*.pyc
*.pyo
*.pyd
__pycache__/
.git/
.github/
!ignore
```

The terminal window title bar indicates the current directory is `~/projeto_final_devops/Task-Manager-using-Flask/todo_project`. The bottom status bar of the nano editor shows various keyboard shortcuts for editing and navigation.

(Exibe o arquivo `.dockerignore` aberto no nano, isolando pastas locais e arquivos de controle do Git).

Mecanismo de Deploy Automático em Review / Stage

A pipeline foi desenhada para monitorar as branches qualificadas (stage). A cada push validado, a esteira reconstrói a imagem Docker e executa os testes dinâmicos acoplados para garantir que nenhuma regressão de código ou falha de infraestrutura quebre o servidor de testes de aceitação.

```
Sessão Ações Editar Exibir Ajuda
[venv]@claydon:~/projeto_final_devsecops/Task-Manager-using-Flask/todo_project$ cat .github/workflows/deploy.yml
name: DevSecOps Pipeline
on:
  push:
    branches: [ development, staging, production ]
  pull_request:
    branches: [ development, staging, production ]
jobs:
  build-and-test:
    runs-on: ubuntu-latest
    steps:
      - name: Checkout Source Code
        uses: actions/checkout@v3
      - name: Set up Python Environment
        uses: actions/setup-python@v4
        with:
          python-version: '3.11'
      - name: Install System Dependencies
        run: |
          sudo apt-get update
          sudo apt-get install -y python3-dev
      - name: Install Python Requirements
        run: |
          python -m pip install --upgrade pip
          pip install flask-sqlalchemy flask-login flask-wtf flask-bcrypt --upgrade
          pip install -r requirements.txt --ignore-installed
      - name: Execute Application Environment Check
        run: |
          python -m compileall .
      - name: Run SAST Security Scan (Bandit)
        run: |
          pip install bandit
          bandit -r . -v
      - name: Run SCA Dependency Scan (Safety)
        run: |
          pip install safety
          safety check
```

```
Sessão Ações Editar Exibir Ajuda
[venv]@claydon:~/projeto_final_devsecops/Task-Manager-using-Flask/todo_project$ docker build -t task-manager-app .
[+] Building 40.0s (10/10) FINISHED
=> [internal] load build definition from Dockerfile
=> transferring Dockerfile: 201B
=> [internal] load metadata for docker.io/library/python:3.11-slim
=> [internal] load dockerignore
=> transferring context: 101B
=> [1/5] FROM docker.io/library/python:3.11-slim@sha256:c32f86c4364a6881bde1ec0c2b6506c53b7a3a774a5a88e6f17a185eaf
=> resolve docker.io/library/python:3.11-slim@sha256:c32f86c4364a6881bde1ec0c2b6506c53b7a3a774a5a88e6f17a185eaf
=> sha256:c32f86c4364a6881bde1ec0c2b6506c53b7a3a774a5a88e6f17a185eaf 10.37kB / 10.37kB
=> sha256:3a2c2932e66780372de0313b283d491c39e87ced7fc55a62bcf9a66d2c01 1.75kB / 1.75kB
=> sha256:7865260727250808fcd80bcdd4f986c7f4861c0994d10902d5060c1 5.51kB / 5.51kB
=> sha256:72c8328f1363a3f061d2f98584cf108ba03fe2f511ed20050c821315d7c97 26.79kB / 26.79kB
=> sha256:9978f4c20ff16c809810d0b19802a3005b31a8e3e106f4f42237908fed24c 1.29kB / 1.29kB
=> sha256:b4ee324f4e0708c727402a1c0979124431734402130e4090b0e0e240 11.49kB / 11.49kB
=> sha256:c751804f29118f4675363b48979bacfb648c795489a129cf0da712e003e 24.0B / 24.0B
=> extracting sha256:72c8328f1363a3f061d2f98584cf108ba03fe2f511ed20050c821315d7c97 1.3s
=> extracting sha256:9978f4c20ff16c809810d0b19802a3005b31a8e3e106f4f42237908fed24c 0.15s
=> extracting sha256:b4ee324f4e0708c727402a1c0979124431734402130e4090b0e0e240 0.55s
=> extracting sha256:c751804f29118f4675363b48979bacfb648c795489a129cf0da712e003e 0.05s
=> [internal] load build context
=> transferring context: 3.45kB
=> [2/5] WORKDIR /app
=> [3/5] COPY requirements.txt .
=> [4/5] RUN pip install --no-cache-dir -r requirements.txt
=> [5/5] COPY . .
=> exporting image
=> writing image sha256:9caded0999fd59a3b70b15574f881c3a936ff73cdea816018f02377a935a
=> naming to docker.io/library/task-manager-app

[venv]@claydon:~/projeto_final_devsecops/Task-Manager-using-Flask/todo_project$ docker run -p 5000:5000 task-manager-app
* Serving Flask app "todo_project"
* Debug mode: on
WARNING: This is a development server. Do not use it in a production deployment. Use a production WSGI server instead.
 * Running on http://127.0.0.1:5000
Press CTRL-C to quit
 * Restarting with stat
 * Debugger is active!
 * Debugger PIN: 104-844-909
```

(Provam a compilação local da imagem do container completando as 10 subetapas com sucesso e expondo o serviço na porta 5000).

ETAPA 7: MONITORAMENTO E ALERTA DE ANOMALIAS

Ferramenta e Configuração

- **Mecanismo Central:** Coleta automatizada via Syslog do Linux em escuta direta no arquivo de socket do sistema.

Regra de Alerta para Detecção de Ataques de Força Bruta

A segurança do perímetro analisa os logs centralizados vindos da aplicação identificados pela tag TASK-MANAGER. A regra automatizada foi definida com a seguinte lógica de correlação:

$$F = \frac{O}{\Delta t}$$

where F is the frequency, O is the number of occurrences of the string `AUDIT_AUTH_FAILURE`, and Δt is the time interval.

Lógica Condicional da Regra: Se o analisador capturar mais de 5 ocorrências contendo a string de auditoria `AUDIT_AUTH_FAILURE` originadas do mesmo endereço IP em um intervalo de tempo (Δt) menor ou igual a 60 segundos, o sistema gera um alerta de severidade Alta/Crítica. Esta ação dispara um gatilho de defesa automatizado que adiciona o IP de origem às regras de restrição do firewall local, mitigando o ataque de força bruta em tempo real.

ETAPA 8: ARQUIVO DE PIPELINE COMPLETO

(.github/workflows/devsecops.yml)

O workflow automatizado foi integrado de forma definitiva à raiz do repositório da aplicação, garantindo a execução contínua dos estágios de segurança a cada nova alteração de código:

YAML

name: Pipeline DevSecOps Task Manager

on:

push:

branches: [stage, production]

jobs:

test:

runs-on: ubuntu-latest

steps:

- uses: actions/checkout@v4

- name: Set up Python

uses: actions/setup-python@v5

with:

python-version: '3.13'

- name: Install Dependencies

run: |

python -m pip install --upgrade pip

**pip install flask flask-sqlalchemy flask-bcrypt flask-login flask-wtf
email_validator**

- name: Run Integration and Functional Tests

run: python test_integration_functional.py

sast_sca:

runs-on: ubuntu-latest

needs: test

steps:

- uses: actions/checkout@v4

- name: Run SCA (Trivy)

uses: aquasecurity/trivy-action@master

with:

scan-type: 'fs'

format: 'table'

- name: Run SAST (Bandit)

run: |

pip install bandit

bandit -r . -f txt -o resultado_bandit.txt

deploy_stage:

runs-on: ubuntu-latest

needs: sast_sca

environment: stage

steps:

- name: Deploy to Stage Environment

run: echo "Deploy executado com sucesso no Ambiente de Review/Stage"

```
Sessão Ações Editar Exibir Ajuda
(venv)cleydson@Cleydson: ~/projeto_final_devsecops/Task-Manager-using-Flask

Attempting uninstall: packaging
Found existing installation: packaging 26.2
Uninstalling packaging-26.2:
Successfully uninstalled packaging-26.2
Attempting uninstall: cryptography
Found existing installation: cryptography 49.0.0
Uninstalling cryptography-49.0.0:
Successfully uninstalled cryptography-49.0.0
Successfully installed aiohttp-1.2.0 aiosqlite-0.21.0 argon2-cffi-25.1.0 argon2-cffi-bindings-25.1.0 asgiref-3.11.1 attrs-26.1.0 beautifulsoup4-4.15.0 brotli-1.2.0 browser-cookie3-0.20.1 cryptography-46.0.1 dnspython-2.8.0 h2-4.3.0 hpack-4.1.0 httpx-0.28.1 httpx-ntlm-1.4.0 hyperframe-6.1.0 jeepney-0.9.0 kaitaistruct-0.11 ldap3-2.9.1 lz4-4.4.5 mako-1.3.12 mitmproxy-12.2.3 mitmproxy-linux-0.12.9 mitmproxy-rs-0.12.9 msgpack-1.1.2 packaging-25.0 playwright-1.48.0 publicsuffixlist-2.20191221 pyOpenSSL-26.2.0 pyasn1-0.6.3 pycryptodomex-3.23.0 pye-12.0.1 pylspack-0.3.24 pyParsing-3.3.2 pyperclip-1.11.0 pysnmp-0.12.1 service-identity-26.1.0 socksio-1.0.0 sortedcontainers-2.4.0 soupsieve-2.8.4 tld-0.13.2 tornado-6.5.5 urwid-3.0.5 wapiti-swagger-0.1.9 wapiti3-3.3.0 wcwidth-0.8.1 wproto-1.3.2 zstandard-0.25.0

Wapiti 3.2.10 (wapiti-scanner.github.io)
[*] Be careful! New moon tonight.
[*] ConnectError with URL http://127.0.0.1:5000/
[*] Saving scan state, please wait...
This scan has been saved in the file /home/cleidyson/.wapiti/scans/127.0.0.1_5000_folder_8ba36946.db
[*] Wapiti found 0 URLs and forms during the scan

[*] Launching module ssl
[*] Launching module file
[*] Launching module upload
[*] Launching module sql
[*] Launching module xss
[*] Launching module redirect
[*] Launching module ssrf
[*] Asking endpoint URL https://wapiti3.ovh/get_ssrf.php?session_id=njk7vj for results, please wait...
[*] Launching module exec
[*] Launching module permanentxss

[*] Generating report...
A report has been generated in the file relatorio_dst.html
Open relatorio_dst.html/127.0.0.1_5000_86152026_9120.html with a browser to see this report.

(venv)~(cleydson@Cleydson): ~/projeto_final_devsecops/Task-Manager-using-Flask
└─ wapiti-getcookie http://127.0.0.1:5000
usage: wapiti-getcookie [-h] -u URL [-c COOKIE] [-p PROXY] [--tor] [--credentials] [--auth-user USERNAME] [--auth-password PASSWORD] [--auth-method {basic,digest,ntlm}] [--form-data DATA] [--form-entype DATA]
      [-H HEADERS]
      [-H HEADERS]
      [-H HEADERS]
wapiti-getcookie: error: the following arguments are required: -u/--url, -c/--cookie

(venv)~(cleydson@Cleydson): ~/projeto_final_devsecops/Task-Manager-using-Flask
```

(Fecha o relatório provando o salvamento e versionamento dos arquivos estruturais do GitHub Actions, scripts de teste corrigidos e relatórios de segurança persistidos dentro do Git local).

LIÇÕES APRENDIDAS

A arquitetura de uma esteira DevSecOps integrada prova que a automação de verificações estáticas (SAST) e dinâmicas (DAST) é capaz de blindar a aplicação de forma preditiva. O processo prático evidenciou que mitigações simples na camada de código — como tratamento de pacotes vulneráveis e rastreabilidade por Syslog — bloqueiam riscos sérios antes que os artefatos alcancem o ambiente final de produção.